Data Encryption and Protection — Revised Evidence

AutoClip | TikTok Shop Partner Security Review | 30 October 2026 | Revised evidence edition

Status: PARTIALLY VERIFIED. Token encryption is evidenced in source; database and media encryption at rest require provider proof.

Supported by repository

• The shared crypto module implements AES-256-GCM encryption/decryption for OAuth tokens with a random 96-bit IV and contextual additional authenticated data.

• Server-side functions read the encryption key; privileged service-role credentials are not intended for browser delivery.

• Source code uses HTTPS endpoints; HMAC media tokens provide access authorization, not encryption at rest.

Production proof required

• Confirm deployed TOKEN_ENCRYPTION_KEY exists in Supabase secrets without revealing its value; document ownership, access and rotation.

• Collect Supabase documentation applicable to the project demonstrating encryption at rest for PostgreSQL, backups and Storage objects.

• Verify production HTTPS/TLS for Vercel domains and Supabase endpoints; retain dated tests.

• Review deployed grants/RLS and Storage policies. Encryption and authorization are distinct controls.

Suggested questionnaire wording

• AutoClip encrypts TikTok OAuth tokens at the application layer using AES-256-GCM and uses HTTPS for application/API transport. Encryption of all database records, backups and media at rest must be supported by applicable Supabase provider evidence before it is claimed as verified.

Document control: Owner: AutoClip operator | Approval: pending | Reviewer/date: _____

Evidence rule: Only claim a control as operational after reviewing dated production or workstation evidence. Do not include secrets or personal data in screenshots.